

Week 2: SOC Operations – Alert to Response Cycle

This report documents theoretical knowledge and practical SOC operations covering alert prioritization, incident classification, response, evidence preservation, and a capstone simulation.

1. Alert Priority Levels

- **Alert priority defines how urgently an alert must be handled.**
 - Alert Priority Levels are used in a Security Operations Center (SOC) to determine how urgent a security alert is and how quickly it must be handled. Since SOC systems like SIEM tools (e.g., Wazuh, Splunk, ELK) generate thousands of alerts daily, prioritization ensures that critical threats are addressed first while less important alerts are monitored accordingly.
 - Alert prioritization helps analysts:
 - Reduce alert fatigue
 - Focus on real threats
 - Respond faster to serious incidents
 - Protect critical assets
 - Priority is usually assigned based on:
 - Impact on business
 - Severity of the attack
 - Asset importance
 - Likelihood of exploitation
 - Most SOC environments classify alerts into four levels of severity.
- **Critical alerts involve active exploitation, ransomware, or severe business impact.**
 - Critical alerts represent the highest level of severity and require immediate action from SOC analysts.
 - These alerts indicate that a serious attack is currently happening or has already compromised the system. If not addressed quickly, it may lead to data theft, system shutdown, financial damage, or full network compromise.

Examples of Critical Alerts

- • Ransomware encryption detected
- Active exploitation of a vulnerability
- Data exfiltration activity
- Root/admin privilege compromise
- Malware spreading across the network

Example Scenario

- A SIEM system detects **Log4Shell exploitation attempts** on a production server.
- Log4Shell vulnerability (CVE-2021-44228) has a **CVSS score of 9.8**, which means it can allow **remote code execution** on vulnerable systems.
- Because attackers can gain **complete system control**, the alert is classified as **Critical**.

Response Required

- SOC analysts must:
 - Immediately isolate the affected system
 - Block the attacking IP address
 - Investigate logs and indicators of compromise
 - Patch the vulnerability
 - Report the incident to management
 - Critical alerts are typically escalated to **Tier-2 or Tier-3 analysts**.
- **High alerts include unauthorized access and privilege of escalation.**
 - High alerts indicate **serious security threats** that may lead to system compromise but **do not yet confirm a successful attack**.
 - These alerts require **quick investigation**, but they may not require emergency shutdown or isolation immediately.

Examples of High Alerts

- • Unauthorized admin login attempts
- Privilege escalation attempts

- Suspicious PowerShell execution
- Malware detected but blocked
- Suspicious outbound connections

Example Scenario

- A SIEM tool detects an **administrator's login from an unusual location**.
- This could mean:
 - Credential compromise
 - Insider threat
 - VPN misuse
- Because admin accounts have **high privileges**, this activity is marked as **High Priority**.

Response Required

- SOC analysts should:
 - Verify login activity
 - Check authentication logs
 - Confirm user identity
 - Block suspicious access if necessary
 - Reset compromised credentials
 - High alerts are usually handled by **Tier-1 analysts with escalation if required**.
- **Medium alerts include brute-force attempts or blocked malware.**
 - Medium alerts represent **moderate security risks** that may indicate suspicious behavior but do not immediately threaten the system.
 - These alerts often indicate **early-stage attack activities** such as scanning or credential guessing.

Examples of Medium Alerts

- - Brute-force login attempts
 - Multiple failed authentication attempts
 - Suspicious file downloads

- Blocked malware activity
- Unusual network traffic patterns

Example Scenario

- A server detects **multiple failed SSH login attempts** from a single IP address.
- This may indicate a **brute-force attack**, where attackers attempt many passwords to gain access.
- Although the attack is suspicious, it may not yet be successful. Therefore, it is classified as **Medium priority**.

Response Required

- SOC analysts should:
 - Monitor the source IP
 - Check authentication logs
 - Implement account lockout policies
 - Block the attacker if attempts continue
 - Medium alerts are usually **monitored and investigated but not escalated immediately**.
- **Low alerts include reconnaissance and policy violations.**
 - Low alerts represent **minor security events** that do not pose immediate risk but may indicate **reconnaissance or policy violations**.
 - These alerts are useful for **long-term monitoring and threat intelligence analysis**.

Examples of Low Alerts

- - Network port scans
 - Policy violations
 - Unusual but harmless traffic
 - Suspicious but unconfirmed activity

Example Scenario

- A firewall detects a **port scan targeting multiple ports on a server**.
- Port scans are often performed by attackers to **identify open services**, but they do not always lead to immediate compromise.
- Therefore, this alert is classified as **Low Priority**.

Response Required

- SOC analysts should:
 - Log the activity
 - Monitor the source IP
 - Add the IP to threat intelligence lists if needed
 - Continue observation for repeated activity
- Low alerts usually **do not require immediate action** but help in identifying potential attackers.

- **CVSS scoring helps quantify risk. Example: Log4Shell CVSS 9.8 is classified as Critical.**

- The **Common Vulnerability Scoring System (CVSS)** is a standardized framework used to **measure the severity of software vulnerabilities**.
- CVSS assigns a **numerical score between 0 and 10** based on several factors:
 - Attack complexity
 - Privileges required
 - Impact on confidentiality
 - Impact on integrity
 - Impact on availability

CVSS Severity Levels

Score	Severity Level
0.0	None
0.1 – 3.9	Low
4.0 – 6.9	Medium
7.0 – 8.9	High

9.0 – 10.0

Critical

Example: Log4Shell Vulnerability

- Vulnerability: **CVE-2021-44228 (Log4Shell)**
CVSS Score: **9.8**
- This vulnerability allows attackers to:
 - Execute remote code
 - Take control of servers
 - Steal sensitive data
- Because of the **extremely high impact and easy exploitation**, it is classified as **Critical**.
- SOC teams use CVSS scores to:
 - Prioritize patching
 - Assign alert severity
 - Focus on high-risk vulnerabilities first

2. Incident Classification

Incident Classification is the process of **categorizing security incidents based on their type, attack method, and impact on the organization**. In a **Security Operations Center (SOC)**, analysts receive alerts from multiple sources such as **SIEM systems, IDS/IPS, firewalls, and endpoint security tools**. Without proper classification, it becomes difficult to **analyze threats, investigate incidents efficiently, and respond quickly**.

Incident classification ensures that **similar security events are grouped together and handled using standardized investigation procedures**. This improves the **speed, accuracy, and consistency of incident responses**.

Proper classification helps organizations to:

- Identify the nature of attacks
- Prioritize investigation and response
- Track attack patterns and trends
- Improve threat intelligence

- Maintain consistent reporting across security teams

- **Incident classification ensures consistency and faster investigations.**

- Incident classification is essential because security teams handle **hundreds or thousands of alerts every day**. By categorizing incidents into specific types, analysts can quickly determine:
 - **What kind of attack is happening?**
 - **Which systems are affected by?**
 - **How serious is the incident?**
 - **What response procedure should be followed?**
- For example, if an alert is classified as **phishing**, the SOC team immediately knows that they must **analyze email headers, check malicious links, and identify affected users**.
- This structured approach allows SOC teams to **respond faster and reduce investigation time**.

- **Common categories include malware, phishing, DDoS, insider threats, and data exfiltration.**

- Security incidents are commonly classified into several categories based on the **type of threat or attack technique** used by attackers.

Malware

- Malware refers to **malicious software designed to damage, disrupt, or gain unauthorized access to systems**.
- Examples include:
 - Ransomware
 - Trojans
 - Spyware
 - Worms
 - Rootkits

- Malware incidents occur when malicious files or programs are detected on a system. These threats may **steal data, encrypt files, or allow attackers to remotely control systems**.
- Example scenario:
- A SIEM alert detects a suspicious executable file named **crypto_locker.exe** running on a server. This may indicate **ransomware activity**, and the incident would be classified as a **Malware Incident**.

Phishing

- Phishing is a **social engineering attack** where attackers send fraudulent emails or messages to trick users into revealing sensitive information such as:
- Passwords
- Credit card numbers
- Login credentials
- Phishing emails often appear to come from **trusted organizations like banks, companies, or government agencies**.
- Example scenario:
- An employee receives an email claiming to be from the IT department requesting them to **reset their password using a suspicious link**. If the link leads to a fake login page designed to steal credentials, the incident is classified as a **Phishing Attack**.
- Phishing attacks are extremely common and are often the **starting point for larger cyberattacks**.

Distributed Denial of Service (DDoS)

- A Distributed Denial of Service (DDoS) attack occurs when attackers **flood a server or network with massive amounts of traffic**, causing the system to become slow or completely unavailable.
- In a DDoS attack, traffic is often generated from **multiple compromised systems (botnets)** across different locations.
- Example scenario:

- A website suddenly receives **millions of requests per minute**, causing the server to crash and preventing legitimate users from accessing the service.
- This type of activity is classified as a **DDoS Incident**.

Insider Threats

- An Insider Threat occurs when **employees, contractors, or trusted individuals misuse their access privileges** to harm the organization.
- These threats can be either:
 - **Malicious insiders** intentionally stealing or leaking data
 - **Negligent insiders** accidentally exposing sensitive information
- Example scenario:
 - An employee copies confidential company data to a personal USB drive or sends it to an external email account without authorization.
- Such activity is classified as an **Insider Threat Incident**.

Data Exfiltration

- Data exfiltration refers to **unauthorized transfer of sensitive information from an organization's systems to an external location**.
- Attackers often attempt to steal:
 - Customer information
 - Financial records
 - Intellectual property
 - Confidential documents
- Example scenario:
 - A monitoring system detects **large amounts of sensitive data being uploaded to an unknown external server** late at night.
- This activity could indicate **data theft**, and the incident would be classified as **Data Exfiltration**.

- **MITRE ATT&CK; mapping example: Phishing emails map to technique T1566.**

- To standardize incident classification, cybersecurity teams use frameworks such as the **MITRE ATT&CK framework**.
- MITRE ATT&CK is a **globally recognized knowledge base of attacker tactics and techniques** used in real-world cyberattacks.
- It helps SOC analysts:
 - Identify attacker behavior
 - Map incidents to known attack techniques
 - Understand how attacks progress through different stages
 - Each technique in the framework has a **unique identifier**.

Example: Phishing Attack Mapping

- A phishing email attack is mapped to:
 - Technique ID: **T1566 – Phishing**
 - This technique belongs to the **Initial Access** tactic, which means attackers are attempting to gain initial entry into the system.
 - Example mapping:

Incident Type	MITRE Technique	Technique ID
Phishing Email	Phishing	T1566

- Using MITRE ATT&CK allows SOC teams to **understand how attackers operate and build better detection rules**.

- **Incidents are enriched with metadata such as affected systems, IP addresses, and timestamps.**

- Once an incident is classified, analysts add **additional contextual information known as metadata**. This process is called **incident enrichment**.
- Metadata provides **important technical details that help investigators analyze the attack more effectively**.
- Common metadata fields include:

Affected Systems

- This identifies the **devices or servers impacted by the incident**.

- Examples:
- Production server
- User workstation
- Database server
- Web application server
- Knowing the affected systems helps determine the **potential impact of the attack**.

IP Addresses

- The source IP address indicates **where the attack originated from**, while the destination IP shows **which system was targeted**.
- Example:
- Source IP: **192.168.1.100**
Destination IP: **192.168.1.50**
- This information helps analysts **trace attacker activity and block malicious sources**.

Timestamps

- Timestamps record the **exact time when the incident occurred**.
- Example:
- 2025-08-18 14:30:00
- Timestamps help investigators:
- Create a timeline of the attack
- Understand when the breach started
- Identify related events in system logs

Indicators of Compromise (IOCs)

- Indicators of Compromise are **forensic artifacts that indicate malicious activity within a system or network**.
- Common IOCs include:

- Malicious file hashes
- Suspicious domain names
- Malicious IP addresses
- Unusual processes
- Example:
 - File Hash: a3f5d2e8c9...
 - Malicious IP: 192.168.1.100
- IOCs help SOC analysts **identify and track attackers across different systems.**

3. Incident Response Lifecycle

The **Incident Response Lifecycle** is a structured process used by cybersecurity teams to **detect, analyze, contain, and recover from security incidents**. It provides a systematic approach for handling cyber threats while minimizing damage to systems, data, and business operations.

Most organizations follow the **incident response framework defined by NIST Special Publication 800-61**, which outlines several key phases of incident handling. These phases ensure that security incidents are handled efficiently and consistently across the organization.

The lifecycle includes the following stages:

1. Preparation
2. Identification
3. Containment
4. Eradication
5. Recovery
6. Lessons Learned

Each stage plays an important role in managing and resolving cybersecurity incidents.

- **Preparation includes tools, playbooks, and access control.**

- Preparation is the **first and most important phase of the incident response lifecycle**. In this stage, organizations prepare their infrastructure, security teams, and procedures to effectively handle potential security incidents.
 - Preparation includes setting up **security tools, defining incident response plans, creating playbooks, and establishing access control mechanisms**. Proper preparation ensures that the SOC team can quickly respond to threats without confusion or delays.
 - Key activities during this phase include:
 - Deploying security tools such as **SIEM systems, intrusion detection systems (IDS), endpoint protection, and monitoring platforms**
 - Creating **incident response playbooks** that define how specific attacks should be handled
 - Establishing **communication protocols** between security teams, management, and stakeholders
 - Defining **roles and responsibilities** for SOC analysts and incident responders
 - Implementing proper **access control policies** to restrict unauthorized access
 - For example, a SOC team may create a **phishing response playbook** that outlines the steps analysts must follow when a phishing email is detected.
 - Preparation helps ensure that organizations are **ready to respond quickly and effectively when a real attack occurs**.
- **Identification involves alert validation and triage.**
 - The Identification phase focuses on **detecting and confirming whether a security event is actually a security incident**. Security tools generate many alerts, but not all alerts indicate a real attack. SOC analysts must investigate these alerts to determine their legitimacy.
 - This phase involves **alert validation and triage**, where analysts examine logs, alerts, and system activity to determine whether suspicious behavior represents a real threat.
 - Key activities in this phase include:
 - Reviewing alerts generated by **SIEM platforms such as Wazuh**
 - Analyzing logs from systems, firewalls, and applications
 - Validating whether the alert is a **true positive or a false positive**
 - Determining the **severity and priority level** of the incident
 - Collecting initial indicators of compromise (IOCs)

- For example, if a monitoring system detects **multiple failed SSH login attempts from the same IP address**, analysts may classify it as a **brute-force attack attempt**.
- Once the threat is confirmed, the incident moves to the next stage.
- **Containment isolates affected systems.**
 - Containment is the process of **limiting the spread and impact of a security incident**. The goal of this phase is to prevent attackers from causing further damage while the investigation continues.
 - In this stage, security teams take immediate action to **isolate affected systems or block malicious activity**.
 - Containment can be divided into two types:
 - **Short-Term Containment**
 - Immediate actions taken to stop the attack temporarily.
 - Examples include:
 - Disconnecting an infected system from the network
 - Blocking malicious IP addresses
 - Disabling compromised user accounts
 - **Long-Term Containment**
 - Actions taken to ensure the attacker cannot regain access.
 - Examples include:
 - Applying security patches
 - Implementing additional monitoring
 - Strengthening firewall rules
 - For example, if ransomware is detected on a workstation, the SOC team may **disconnect the system from the network to prevent the malware from spreading to other devices**.
- **Eradication removes malicious artifacts.**
 - After the threat has been contained, the next step is **removing the root cause of the incident from the environment**. This phase is called eradication.

- During eradication, analysts identify and eliminate **malicious files, backdoors, unauthorized user accounts, and vulnerabilities** that allowed the attack to occur.
 - Key activities include:
 - Removing malware or malicious scripts
 - Deleting unauthorized user accounts
 - Patching software vulnerabilities
 - Cleaning infected systems
 - Conducting forensic analysis to ensure no hidden threats remain
 - For example, if a system was infected with malware, analysts may **delete the malicious files and update the antivirus signatures to prevent reinfection**.
 - The goal of eradication is to **completely eliminate the attacker's presence from the environment**.
- **Recovery restores normal operations.**
 - The Recovery phase focuses on **restoring normal business operations after the threat has been removed**. Systems that were affected by the incident must be carefully restored and monitored to ensure that they are functioning properly.
 - Recovery activities include:
 - Restoring systems from **clean backups**
 - Reconnecting isolated systems to the network
 - Verifying system integrity
 - Monitoring systems for any signs of reinfection
 - Ensuring services are fully operational
 - For example, if a database server was compromised, the organization may **restore the server from a secure backup and verify that the data has not been altered**.
 - During this phase, organizations must also ensure that **additional security controls are in place to prevent similar incidents in the future**.
- **Lessons learned to improve future response.**
 - The final phase of the incident response lifecycle is **Lessons Learned**. In this stage, security teams analyze the incident to understand **what happened, why it happened, and how similar incidents can be prevented in the future**.
 - This phase typically involves conducting a **post-incident review or post-mortem analysis**.
 - Key activities include:

- Reviewing the timeline of the attack
- Identifying weaknesses in security controls
- Evaluating the effectiveness of the incident response process
- Updating incident response playbooks
- Improving monitoring and detection mechanisms
- Training employees based on lessons learned
- For example, if a phishing attack successfully compromised user credentials, the organization may decide to:
 - Implement **multi-factor authentication (MFA)**
 - Provide additional **security awareness training**
 - Deploy stronger **email filtering solutions**
 - Documenting lessons learned helps organizations **continuously improve their security posture and incident response capabilities.**

4. Alert Management Practice

Alert management is a crucial responsibility of a **Security Operations Center (SOC)**. It involves identifying, categorizing, prioritizing, and responding to security alerts generated by monitoring tools such as SIEM systems. Proper alert management helps security analysts detect real threats quickly while reducing time wasted on false positives.

During this task, several alert management activities were practiced to simulate how a SOC analyst handles security alerts in real-world scenarios.

- **Alerts were categorized and prioritized using Google Sheets.**
 - In this exercise, alerts were organized and prioritized using **Google Sheets**, which acted as a simplified alert tracking system. Each alert was recorded in a structured format that allowed analysts to easily track, evaluate, and manage security incidents.
 - The spreadsheet contained fields such as:
 - Alert ID
 - Alert Type
 - Priority Level
 - Description
 - Source IP
 - Status

- MITRE ATT&CK Mapping
- This structured approach helped simulate how alerts are tracked in professional SOC platforms.
- Alerts were categorized into different priority levels such as:
 - **Critical**
 - **High**
 - **Medium**
 - **Low**
- The priority was determined based on factors such as:
 - Severity of the threat
 - Impact on systems
 - Likelihood of exploitation
 - CVSS score of associated vulnerabilities
- Using a spreadsheet allows analysts to **visualize and manage alerts efficiently**, similar to real SOC alert dashboards.

- **Mock alerts such as Log4Shell and Port Scans were evaluated.**

- To simulate real-world SOC operations, several **mock alerts** were created and analyzed.
- One of the major simulated alerts was **Log4Shell (CVE-2021-44228)**, which is a critical vulnerability affecting the Apache Log4j logging library. This vulnerability allows attackers to execute remote code on vulnerable systems. Because the CVSS score of Log4Shell is **9.8**, it was categorized as a **Critical severity alert**.
- Another simulated alert involved a **port scanning activity**, where an attacker attempts to discover open ports on a target system. Port scanning is commonly used by attackers during the reconnaissance phase of an attack.
- These alerts were evaluated based on:
 - Severity of the threat
 - Potential impact on systems
 - CVSS scoring
 - Likelihood of exploitation
- For example:

Alert Type	Description	Priority
------------	-------------	----------

Log4Shell Exploit	Remote code execution vulnerability	Critical
Port Scan Detected	Multiple ports scanned from external IP	Low

- Evaluating these alerts helped simulate how SOC analysts analyze different threat scenarios.

- **Incident tickets were created in TheHive.**

- After identifying and prioritizing alerts, incident cases were documented using **TheHive**, which is an open-source incident response platform used by SOC teams.
- In TheHive, an **incident ticket** was created to document a simulated security incident. The incident ticket included important information such as:
 - Incident Title
 - Description of the attack
 - Indicators of Compromise (IOCs)
 - Priority Level
 - Assigned Analyst
- Example ticket information:
 - Title: **[Critical] Ransomware Detected on Server-X**
 - Description:
Indicators identified during analysis include a suspicious file named **crypto_locker.exe** and malicious network activity originating from **192.168.1.50**.
 - Priority: **Critical**
 - Assignee: **SOC Analyst**
- Creating incident tickets helps maintain a **structured investigation process** and ensures proper tracking of security incidents.

- **Escalation procedures were practiced.**

- Escalation is an important process in SOC operations. When a **Tier 1 analyst detects a high-risk alert**, the incident must be escalated to a higher-level analyst for deeper investigation.

In this exercise, a simulated escalation procedure was performed where a **Critical alert was escalated to a Tier 2 analyst**.

The escalation included summarizing key information about the incident such as:

- Type of attack
- Affected system
- Indicators of compromise
- Initial investigation results

Example escalation summary:

A critical security alert was detected indicating potential ransomware activity on Server-X. Initial analysis identified a suspicious executable file named `crypto_locker.exe` and malicious network communication from IP address 192.168.1.50. The affected system has been isolated from the network for containment. Further investigation is required to determine the extent of the compromise.

Practicing escalation procedures help ensure that **serious security incidents receive immediate attention from experienced analysts.**

5. Response Documentation

Response documentation is an important part of **incident response management** in a Security Operations Center (SOC). Proper documentation ensures that every step taken during a security investigation is recorded for accountability, analysis, and future improvement. It also helps organizations maintain compliance with cybersecurity standards and provides a clear record of how incidents were handled.

During this task, several response documentation activities were performed, including creating incident response templates, documenting investigation timelines, preparing phishing response checklists, and conducting post-incident analysis.

- Incident response templates were created based on SANS standards.

- Incident response templates were designed based on best practices recommended by the **SANS Institute**, which is a globally recognized cybersecurity training and research organization.
- These templates provide a structured format for documenting security incidents so that analysts can consistently record critical information.
- The incident response template included the following sections:
 - Incident ID
 - Date and Time of Detection
 - Incident Description
 - Severity Level
 - Affected Systems
 - Indicators of Compromise (IOCs)
 - Actions Taken
 - Analyst Name
- Using a standardized template ensures that all incidents are documented consistently and makes it easier for security teams to review and audit investigations later.

- **Investigation timelines and action logs were documented.**

- During the incident investigation process, a detailed **timeline of events** was created to track how the incident unfolded and how it was handled by the security team.
- The investigation timeline included:
 - Time when the alert was generated
 - Time when the analyst started investigating
 - Actions taken during the investigation
 - Time when containment measures were applied
 - Final resolution time
- An **action log** was also maintained to record every step taken by the analyst during the investigation. This included activities such as reviewing logs, isolating affected systems, blocking malicious IP addresses, and removing malicious files.
- Example timeline:

Time	Action
10:05 AM	Security alert triggered
10:10 AM	Analyst started investigation
10:20 AM	Suspicious file identified

10:30 AM	System isolated from network
11:00 AM	Malicious file removed

- Maintaining such records helps organizations perform forensic analysis and understand how incidents develop over time.
- **Phishing response checklists were prepared.**
 - A **phishing response checklist** was created to guide security teams when handling phishing attacks. Phishing attacks are one of the most common cybersecurity threats where attackers attempt to trick users into revealing sensitive information.
 - The checklist included the following steps:
 - Identify the suspicious email and verify whether it is malicious.
 - Analyze the sender's email address and domain.
 - Check email headers for suspicious routing information.
 - Identify any malicious links or attachments.
 - Block the sender's domain if confirmed malicious.
 - Notify affected users about the phishing attempt.
 - Remove the email from other user inboxes if necessary.
 - Using a checklist helps SOC analysts respond quickly and consistently when phishing incidents occur.
- **Post-mortem analysis was conducted.**
 - After the incident investigation was completed, a **post-mortem analysis** was conducted to evaluate how the incident occurred and how the response process could be improved.

The goal of post-mortem analysis is to identify:

- Root cause of the incident
- Weaknesses in the security infrastructure
- Effectiveness of the response strategy
- Areas where detection or response can be improved

For example, if a phishing attack succeeded because employees were unaware of phishing techniques, the organization might implement **security awareness training** to reduce the risk of similar attacks in the future.

Post-mortem analysis is essential for improving an organization's overall cybersecurity posture and ensuring better preparedness for future incidents.

6. Alert Triage Practice

Alert triage is a critical process in a **Security Operations Center (SOC)** where security alerts generated by monitoring tools are analyzed to determine their severity, legitimacy, and required response. Since modern security systems generate a large number of alerts every day, triage helps analysts quickly identify which alerts represent real threats and which are false positives.

During this task, alerts generated by the **Wazuh** security monitoring platform were analyzed, validated using threat intelligence tools, and documented for further investigation.

- **Wazuh alerts were analyzed for severity and validity.**
 - The first step in alert triage involved analyzing alerts generated in the **Wazuh** dashboard. Wazuh is an open-source security monitoring platform that provides **log analysis, intrusion detection, file integrity monitoring, and threat detection**.
 - Each alert generated by the system contains several important details, including:
 - Alert ID
 - Timestamp of the event
 - Source IP address
 - Target system
 - Description of the suspicious activity
 - Alert severity level
 - The alerts were examined to determine whether the activity represented a legitimate security threat or normal system behavior.
 - For example, alerts indicating **multiple failed login attempts** could suggest a brute-force attack, while alerts related to **unexpected file modifications** might indicate potential malware activity.

- The severity levels assigned by Wazuh helped prioritize which alerts required immediate investigation.
- **Threat intelligence validation was performed using VirusTotal and AlienVault OTX.**
 - To verify whether suspicious indicators were malicious, threat intelligence platforms were used to validate the data collected from alerts.
 - Two widely used threat intelligence platforms were used:
 - **VirusTotal**
 - **AlienVault OTX**
 - **VirusTotal Analysis**
 - **VirusTotal** is a security service that analyzes files, URLs, and IP addresses using multiple antivirus engines and threat intelligence databases.
 - During the investigation:
 - Suspicious file hashes were uploaded to VirusTotal.
 - Malicious URLs were checked against known threat databases.
 - IP addresses were verified for malicious activity.
 - If multiple security engines flagged the indicator as malicious, it confirmed that the alert represented a real security threat.

AlienVault OTX Validation

AlienVault OTX (Open Threat Exchange) is a community-driven threat intelligence platform where security researchers share information about cyber threats.

In this step:

- Suspicious IP addresses were searched in the OTX database.
- Threat pulses were checked to identify known attack campaigns.
- Indicators of compromise (IOCs) were validated.

This helped determine whether the activity was part of a **known attack pattern or threat campaign**.

- **False positives were identified and documented.**

- Not every alert generated by a security tool represents a real threat. Sometimes alerts are triggered by legitimate system activities, which are known as **false positives**.

During the triage process, alerts were carefully reviewed to determine whether they were genuine security incidents or harmless system behavior.

Examples of false positives include:

- Internal vulnerability scanning tools triggering alerts
- System administrators performing legitimate configuration changes
- Automated scripts generating unusual but safe network activity

When a false positive was identified:

- The alert details were documented.
- The reason for classifying it as a false positive was recorded.
- Detection rules were reviewed to reduce similar false alerts in the future.

Documenting false positives helps improve the accuracy of security monitoring systems and reduces unnecessary workload for SOC analysts.

7. Evidence Preservation

Evidence preservation is a crucial step in digital forensics and incident response. It ensures that all collected evidence remains **accurate, authentic, and legally admissible** throughout the investigation process. Proper evidence handling allows security analysts and investigators to analyze cyber incidents while maintaining the integrity of the original data.

During the investigation process, volatile data was collected, memory dumps were securely stored and hashed, and chain-of-custody procedures were followed to ensure proper documentation of all evidence.

- **Volatile data was collected using Velociraptor.**

- Volatile data refers to information that exists temporarily in system memory and may be lost when the system is powered off or restarted. This data can include running processes, active network connections, logged-in users, and temporary files that may provide critical insights during an investigation.
- To collect volatile data, the open-source digital forensics tool **Velociraptor** was used.
- Velociraptor is widely used by security teams for:
 - Endpoint monitoring
 - Digital forensic investigations
 - Incident response
 - Evidence collection from compromised systems
- During this process, Velociraptor was used to gather important artifacts such as:
 - Running processes on the affected system
 - Active network connections
 - System logs and event records
 - Suspicious files or processes in memory
- Collecting volatile data early in the investigation helps preserve critical evidence that may disappear if the system state changes.

- **Memory dumps were acquired and hashed using SHA256.**

- A **memory dump** is a snapshot of the system's RAM at a specific point in time. Memory dumps are extremely valuable in forensic investigations because they can reveal hidden malware, injected processes, encryption keys, and other malicious activity that may not appear in normal system logs.
- Once the memory dump was collected, a cryptographic hash was generated using the **SHA-256** hashing algorithm.
- Hashing is performed to ensure **data integrity**. A hash value acts like a digital fingerprint of the file.
- The hashing process provides two important benefits:
 - It verifies that the evidence has not been altered after collection.
 - It allows investigators to confirm that the original file and the analyzed copy are identical.

- If the hash value changes at any stage of the investigation, it indicates that the file has been modified, which could compromise the integrity of the evidence.

- **Chain-of-custody documentation was maintained.**

- The **chain of custody** is a formal record that documents how evidence is collected, handled, transferred, and stored during an investigation. Maintaining this record ensures transparency and accountability throughout the forensic process.

The chain-of-custody documentation included:

- Name of the investigator who collected the evidence
- Date and time of evidence collection
- Description of the collected data
- Hash values of the evidence files
- Location where the evidence was stored
- Details of any transfer or access to the evidence

This documentation ensures that the evidence can be trusted and verified if it is later presented during an internal investigation, audit, or legal proceeding.

Maintaining a proper chain of custody is considered a **best practice in digital forensics and cybersecurity investigations**.

8. Capstone Project

The capstone project represents the complete **Alert-to-Response security workflow** in a Security Operations Center (SOC). In this project, a simulated cyberattack was performed in a controlled lab environment to demonstrate how security tools detect, analyze, respond to, and report security incidents.

The project followed a full cybersecurity lifecycle that included **attack simulation, detection, triage, response, and reporting**. This exercise helped in understanding how real SOC teams handle security threats using multiple tools and frameworks.

- **A Metasploit attack was simulated against Metasploitable2.**

- To simulate a real-world, cyberattack, the penetration testing framework **Metasploit Framework** was used to exploit vulnerabilities in **Metasploitable2**, which is an intentionally vulnerable virtual machine designed for cybersecurity training.
- A known vulnerable service on Metasploitable2 was targeted using a Metasploit exploit module. For example, the **vsftpd backdoor vulnerability** was used to gain unauthorized access to the system.
- The steps included:
 - Launching the Metasploit console
 - Selecting the exploit module
 - Setting the target IP address of Metasploitable2
 - Executing the exploit to establish access
- This simulated an attacker attempting to compromise a vulnerable server in a real network environment.
- The purpose of this stage was to generate malicious activity that could later be detected by security monitoring tools.

- **Wazuh detected and generated alerts.**

- Once the attack was executed, the security monitoring platform **Wazuh** detected suspicious activity on the target system.
- Wazuh works as a **Security Information and Event Management (SIEM)** and a **host-based intrusion detection system**. It monitors system logs, file integrity, network events, and suspicious behaviors.
- During the attack simulation, Wazuh generated alerts related to:
 - Unauthorized service access
 - Exploit activity
 - Suspicious network connections
 - Abnormal system behavior
- These alerts were displayed on the Wazuh dashboard and categorized based on severity levels such as **Critical, High, Medium, and Low**.
- The alerts provided important details including:
 - Timestamp of the event
 - Source IP address of the attacker
 - Description of the detected activity
 - Associated MITRE ATT&CK technique

- This detection phase represents the **Identification stage of incident response**.
- **CrowdSec blocked the attacker's IP.**
 - After confirming the malicious activity, a response action was taken using **CrowdSec**, which is an open-source collaborative security tool used to block attackers automatically.
 - CrowdSec analyzes suspicious traffic patterns and blocks malicious IP addresses using firewall rules.
 - During the response phase:
 - The attacker's IP address was identified from Wazuh alerts
 - CrowdSec applied a blocking rule to prevent further access
 - The firewall automatically denied connections from the attacker's IP
 - This step represents the **Containment stage of the incident response lifecycle**, where the threat is prevented from causing further damage.
 - Blocking the attacker's IP helps protect the system from repeated attacks and reduces the risk of exploitation.
- **A final incident report and management briefing were created.**
 - After the detection and response process was completed, the incident was documented in a detailed report.
 - The incident report included:
 - Executive summary of the attack
 - Timeline of events
 - Tools used during the investigation
 - Indicators of compromise (IOCs)
 - Actions taken to contain the threat
 - Recommendations to prevent similar attacks
 - This documentation ensures that the organization maintains a record of the security incident and improves its security posture.
 - Additionally, a **management briefing** was prepared to communicate the incident to non-technical stakeholders. The briefing summarized the attack, the response actions taken by the SOC team, and the current security status of the system in simple and clear language.
 - This final stage represents the **Lessons Learned and Reporting phase** of the incident response lifecycle.

Conclusion

This project demonstrated the complete **Security Operations Center (SOC) workflow** starting from theoretical understanding to practical implementation of security monitoring and incident response. The objective was to understand how security alerts are generated, analyzed, prioritized, investigated, and finally resolved in a real-world SOC environment.

The project began with learning the **concept of alert priority levels**, where security alerts are categorized into Critical, High, Medium, and Low based on their impact and urgency. Understanding alert prioritization is essential because SOC analysts must quickly identify the most dangerous threats and respond to them before they cause significant damage. Risk scoring systems such as CVSS help in determining the severity of vulnerabilities and assist analysts in making informed decisions.

Next, the project focused on **incident classification**, which helps in organizing security events into categories such as malware, phishing, DDoS attacks, insider threats, and data exfiltration. Frameworks like **MITRE ATT&CK** were used to map attacks to specific tactics and techniques. This standardization improves communication among security teams and helps in faster threat investigation.

The **incident response lifecycle** was then studied and applied. The process included preparation, identification, containment, eradication, recovery, and lessons learned. Each phase plays a critical role in managing security incidents effectively and ensuring that systems return to normal operations while improving future security defenses.

During the **practical implementation phase**, different security tools were used to simulate and analyze alerts. Alerts were categorized and prioritized using Google Sheets with CVSS scoring, while incident tickets were created using **TheHive** for proper documentation and case

management. Security alerts were monitored and analyzed using **Wazuh**, which helped visualize threat severity and system activity.

The project also included **alert triage and threat intelligence validation**, where suspicious indicators were verified using platforms like **VirusTotal** and **AlienVault OTX**. This process helped determine whether alerts were real threats or false positives, which is an important responsibility of SOC analysts.

For **digital forensic investigation**, volatile system data was collected using **Velociraptor**, and evidence of integrity was maintained using SHA256 hashing. Proper chain-of-custody documentation ensured that the collected evidence remained reliable and admissible for investigation purposes.

Finally, the **capstone project** simulated a real cyberattack using the **Metasploit Framework** against the vulnerable **Metasploitable2** environment. The attack was successfully detected by Wazuh, and defensive actions were taken by blocking the attacker's IP using **CrowdSec**. The entire incident was documented through reports and management briefings, completing the full **attack-to-response cycle**.

Overall, this project provided a comprehensive understanding of how modern SOC teams operate. It combined theoretical knowledge with hands-on practice using real security tools to simulate attack detection, investigation, response, and reporting. The experience gained from this project strengthens practical cybersecurity skills and prepares learners for real-world roles such as SOC Analyst, Incident Responder, or Security Operations Engineer.